

用维阵还原 Zyxel 后门漏洞

📅 2021年01月12日
🔍 漏洞分析 (/category/vul-analysis/) · 安全工具&安全开发 (/category/tools/)

作者：km1ng@极光无限维阵漏洞团队
原文链接：<https://mp.weixin.qq.com/s/OI3B3PFLLXLFF8ThA9nxEg>
(<https://mp.weixin.qq.com/s/OI3B3PFLLXLFF8ThA9nxEg>)

一、简介

荷兰网络安全公司Eye Control的安全研究人员发现，超过10万个合勤科技（Zyxel）公司的防火墙、接入点控制器和VPN网关产品中存在管理员级后门账户。这些在二进制代码中硬编码的管理员级别账户使攻击者可通过Web管理面板或SSH界面获得对设备的root访问权限。合勤科技（Zyxel）是一家位于中国台湾新竹的网络设备制造商。Zyxel固件中发现的后门漏洞cve编号为cve-2020-29583等分为7.8 CVSS

二、影响范围

CVE-ID
CVE-2020-29583 Learn more at National Vulnerability Database (NVD) • CVSS Severity Rating • Fix Information • Vulnerable Software Versions • SCAP Mappings • CPE Information
Description
Firmware version 4.60 of Zyxel USG devices contains an undocumented account (zyfwp) with an unchangeable password. The password for this account can be found in cleartext in the firmware. This account can be used by someone to login to the ssh server or web interface with admin privileges.
References
Note: References are provided for the convenience of the reader to help distinguish between vulnerabilities. The list is not intended to be complete.

cve官网上表示USG设备4.60， 真实影响范围如下：

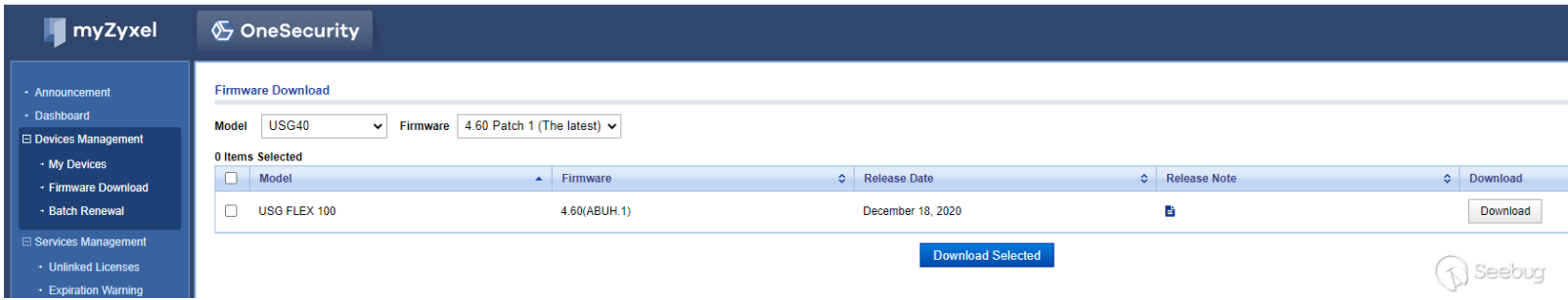
zyxel:ap_controller_nxc_2500: *zyxel:ap_controller_nxc_5500*: zyxel:atp_firmware: 4.60
zyxel:usg_firmware: 4.60 zyxel:usg_flex_firmware: 4.60 zyxel:vpn_firmware: 4.60

三、固件后门分析

3.1、固件下载

下载链接：<https://portal.myzyxel.com/my/firmwares>
(<https://portal.myzyxel.com/my/firmwares>)

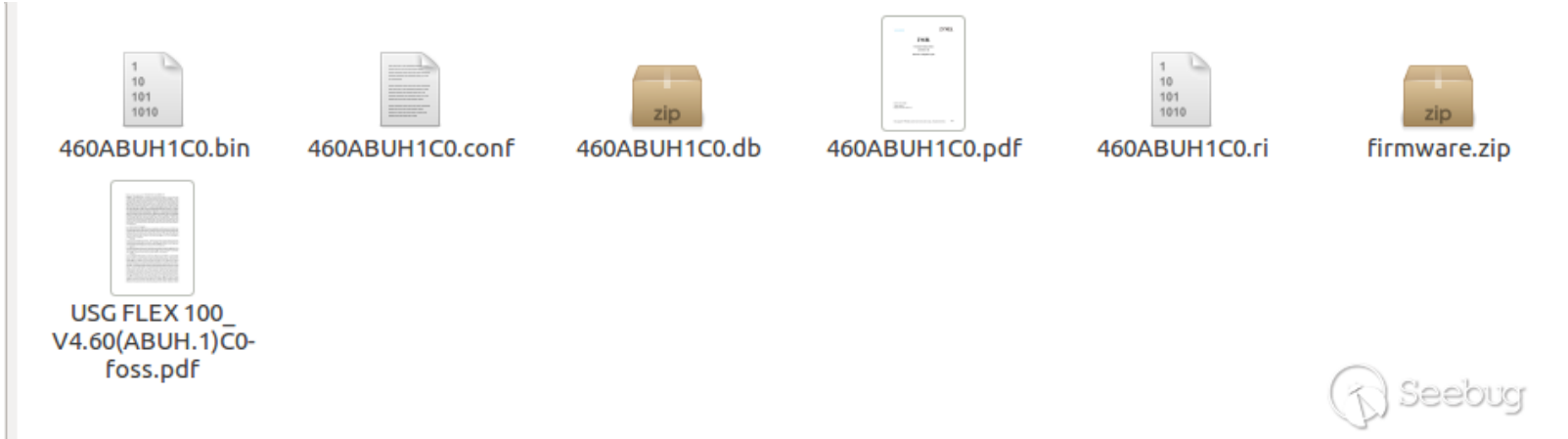
需要注册账户登录，选择USG40固件，4.60版本下载。如下图所示



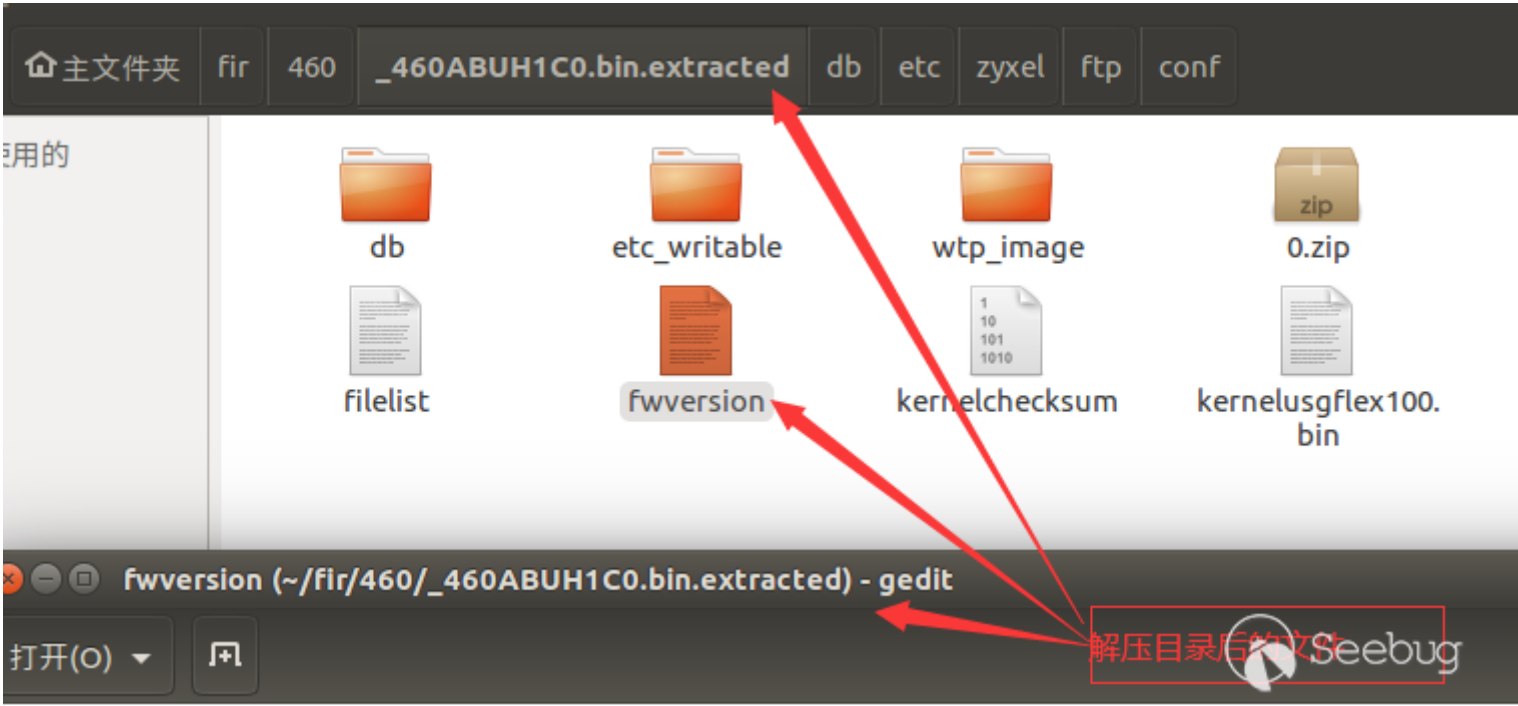
下载后固件是一个名为firmware.zip的压缩包，将这个压缩包放入ubuntu虚拟机下。

3.2、固件解压

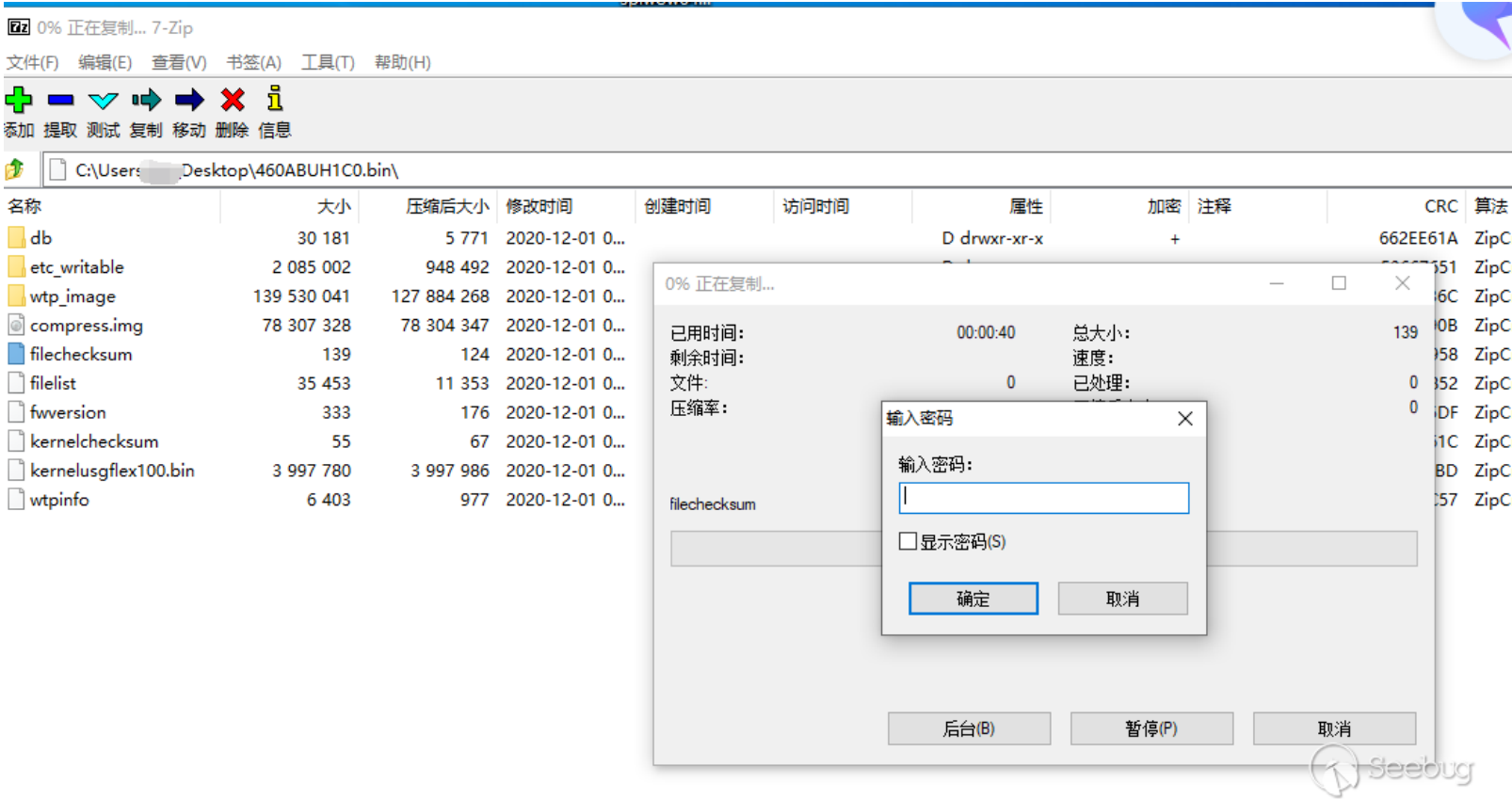
使用unzip firmware.zip解压缩包，可以看到解压出如下文件。



其中的460ABUH1C0.bin就是需要解压的固件。直接使用binwalk -e 解压,会发现解压的全部文件里面内容是空的。



使用file命令查看这个bin文件，发现他是一个zip压缩包文件。将这个bin文件移动到windows下使用7-zip查看目录文件结构。



我们是可以得到一些固件中的信息的，如文件大小等。解压firmware.zip的不只解压出来bin文件，还有其他的一些conf、pdf文件。使用7z工具打开bin文件在里面寻找.conf、pdf后缀文件，第一个就发现了大小为30181的文件，ubuntu下查看解压出来的460ABUH1C0.conf也是30181的大小，现在猜测这两个文件是相同的。



3.3、固件解密

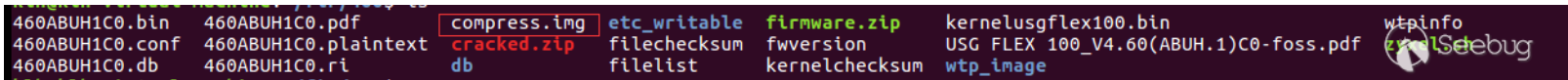
使用pkcrack包进行解密，解密方式为明文攻击，这里不对明文攻击进行详细阐述。pkcrack包在附件给出，解压后进入src目录，直接make即可。

将zyxel.sh脚本和460ABUH1C0.bin放在同一级目录，命令：

```
sudo ./zyxel.sh 460ABUH1C0
```

可以将固件解压出来，解密过程大概会在20秒左右，zyxel.sh也会在附件中给出。

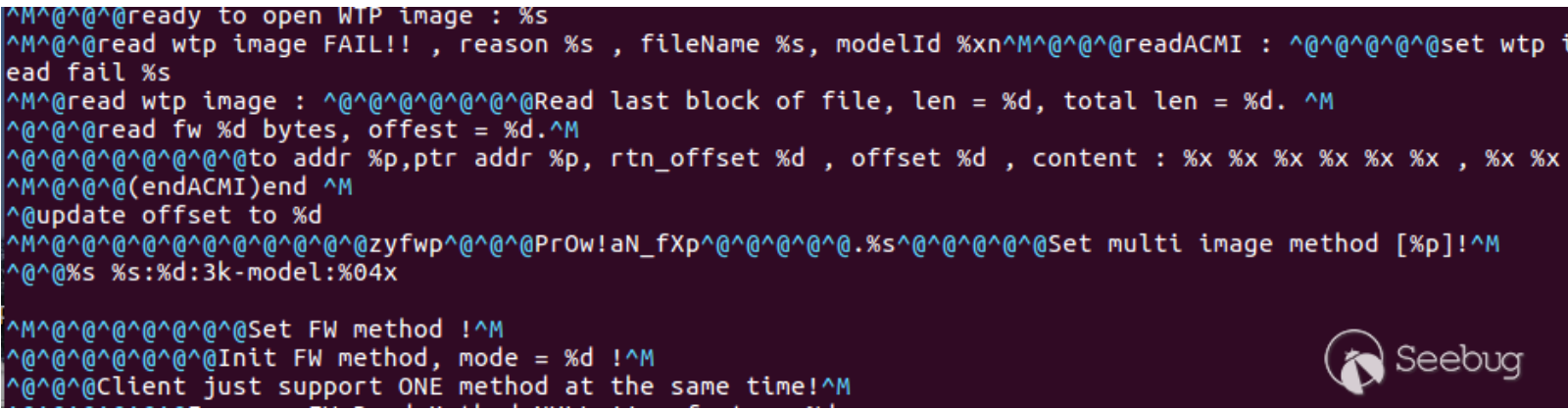
解压完成后，发现当前目录下有cracked.zip压缩包，直接解压即可得到460ABUH1C0.bin中的内容，可以看到里面有compress.img文件这个才是我们最终需要解压的固件，直接使用binwalk -e指令即可。



可以使用file指令查看一下这个文件，会发现Squashfs filesystem。

3.4、搜索后门

因为已爆出了后门账户的账号和密码，这里直接使用grep指令搜索，grep -rn "PrOw!aN_fx" 搜索的密码时候，其中“!”是需要进行转义并不是密码里有“!”字符。打开匹配到的usr/local/bin/capwap/capwap_srv二进制文件。



将这个文件取出，放入ida中分析。

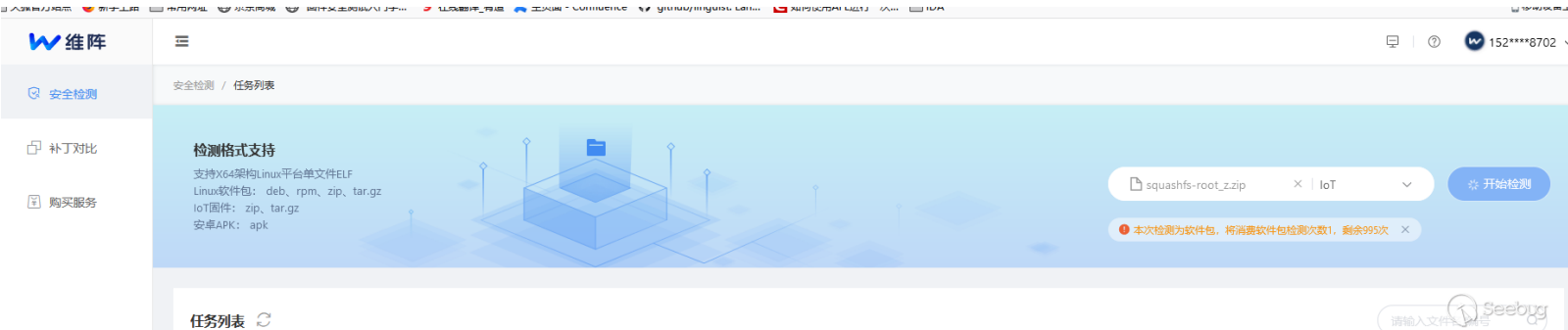
```
1 void __cdecl initACMutIMI(fwInfo_s *fwInfo)
2 {
3     fwInfo->fwUpgradeMethod = 1;
4     fwInfo->ftpPort = 21;
5     fwInfo->ftpID[0] = 'z';
6     fwInfo->ftpID[1] = 'y';
7     fwInfo->ftpID[2] = 'f';
8     fwInfo->ftpID[3] = 'w';
9     fwInfo->ftpID[4] = 'p';
10    fwInfo->ftpID[5] = '\0';
11    strcpy(fwInfo->ftpPwd, "PrOw!aN_fXp");
12    fwInfo->ftpPwd[127] = 0;
13    snprintf(fwInfo->ftpPath, 0x40u, ".%s", byte_10096288);
14    fwInfo->ftpPath[63] = 0;
15    fwInfo->failAction = 0;
16 }
17 }
```

四、维阵固件分析

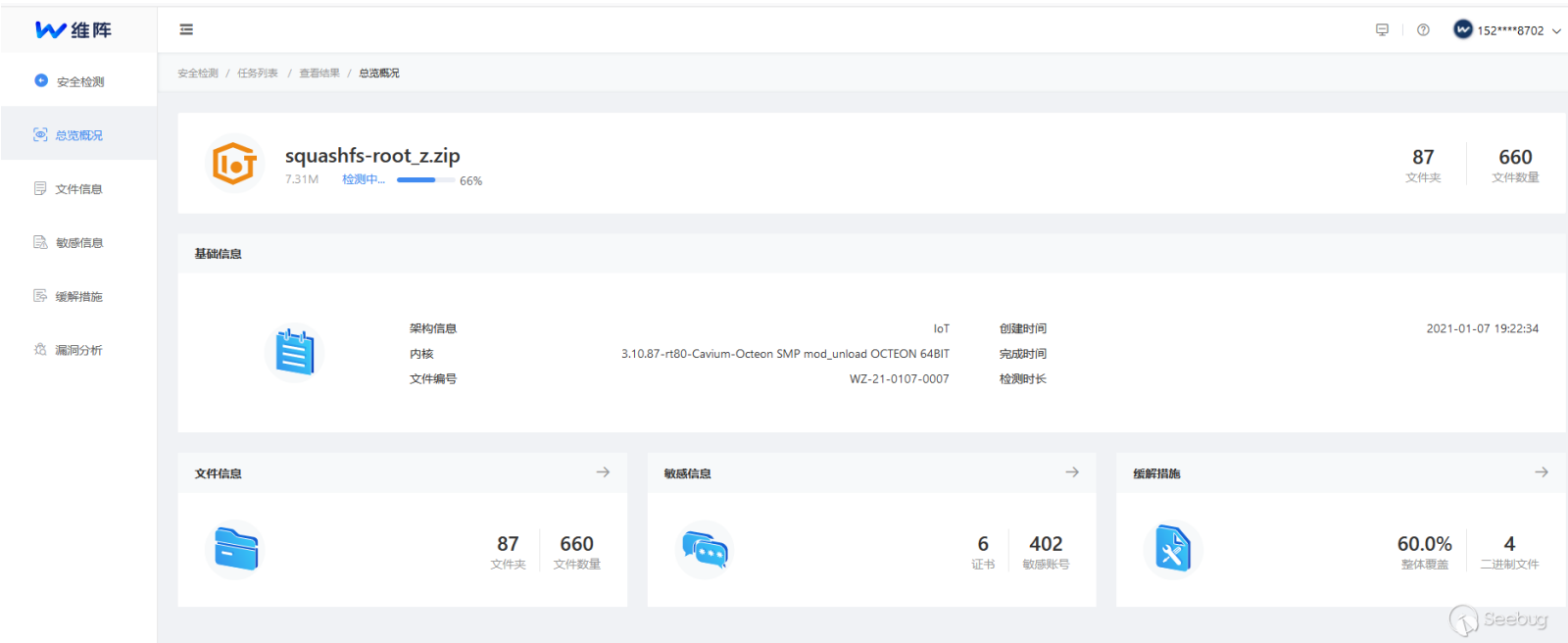
上诉这种情况大概率就是一个后门账户了，现在是已知账号密码可以使用搜索指令确定位置，如何在未知固件中快速发现这种后门账户。

出现上诉类似情况大概率是一个后门账户，据有很高的分析价值。现在是已知账号密码可以使用搜索指令确定其位置。在一个未知固件中找到漏洞、定位漏洞的具体位置是一个费时费力的工程。维阵平台，可以自动化的分析容易出现问题的位置，将感兴趣的文件列举出来如一些账号密码文件，固件的目录结构、组件、判断程序是否开启保护机制等。

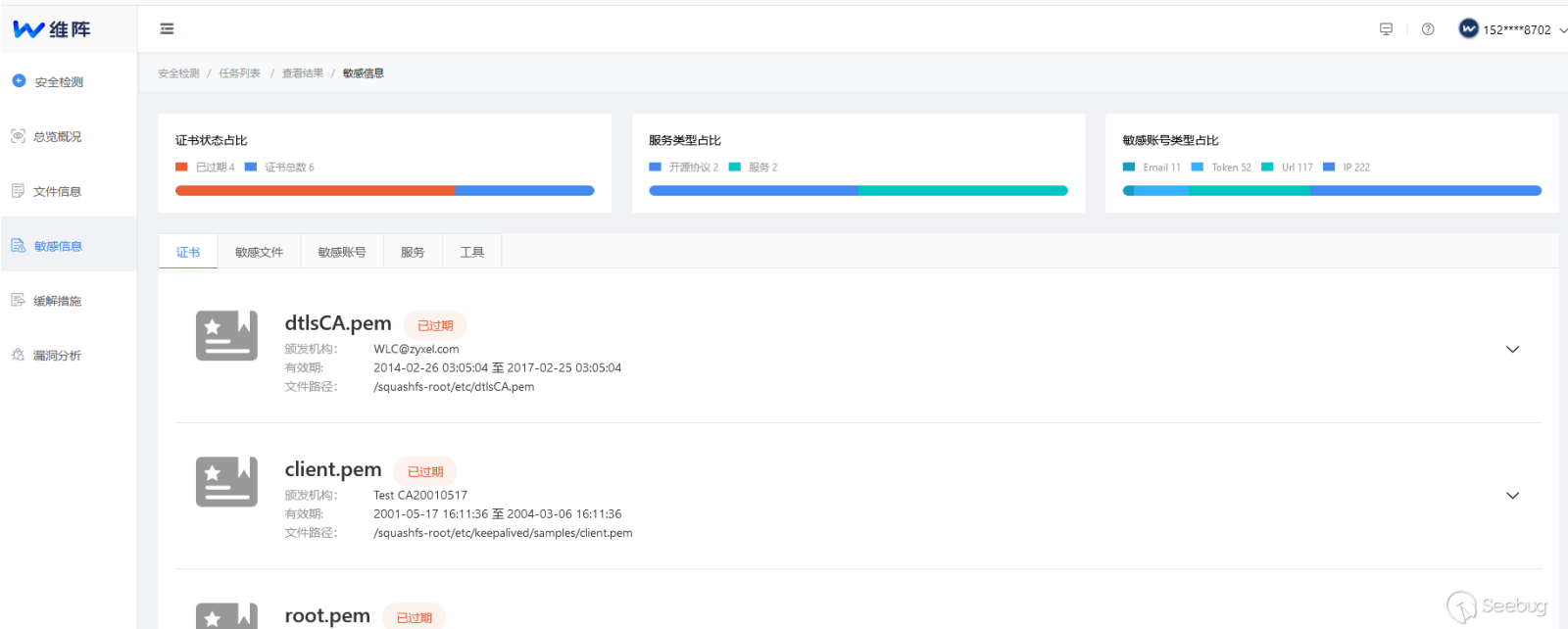
进入compress.img解压出来的_compress.img.extracted目录，使用7z压缩squashfs-root为一个zip包取出，上传到维阵平台。



维阵是实时分析上传的，分析完成前就可以先看到部分结果。



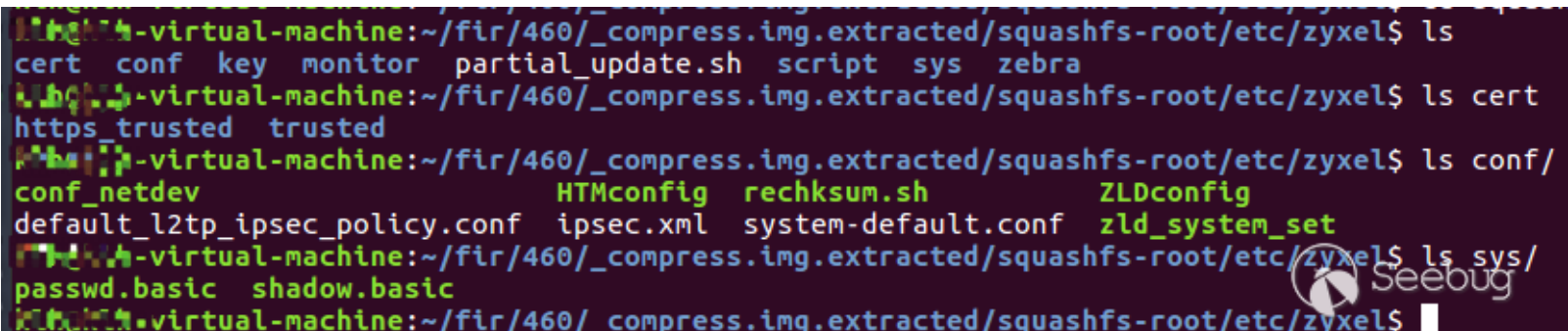
点击敏感账号，进入敏感信息页面。



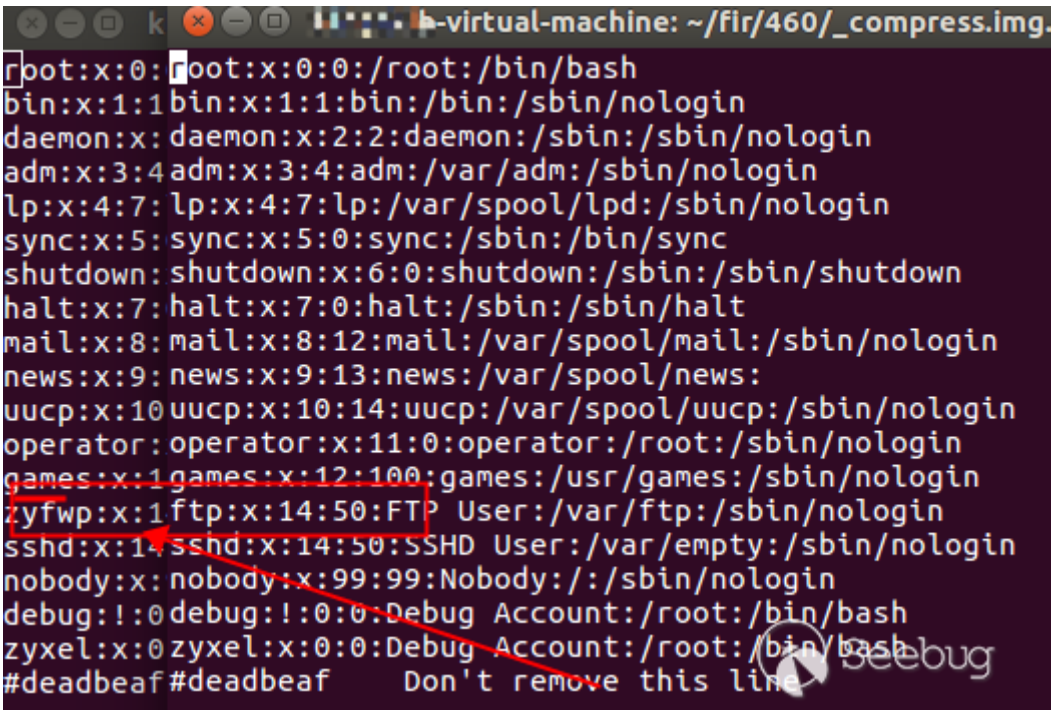
点击工具选项，可以看到有ftp。

证书	敏感文件	敏感账号	服务	工具	
类型	文件名		路径		
传输工具	ssh		/squashfs-root/etc/init.d/ssh		
传输工具	ftp		/squashfs-root/etc/pam.d.basic/ftp		
传输工具	ssh		/squashfs-root/etc/pam.d.basic/ssh		
传输工具	sshd		/squashfs-root/etc/pam.d.basic/sshd		
传输工具	ssh		/squashfs-root/etc/ssh		
传输工具	ssl		/squashfs-root/etc/ssl		
传输工具	telnet		/squashfs-root/etc/xinetd.d/telnet		
传输工具	ftp		/squashfs-root/etc/zyxel/ftp		

去解压后的固件中，查找这个路径。

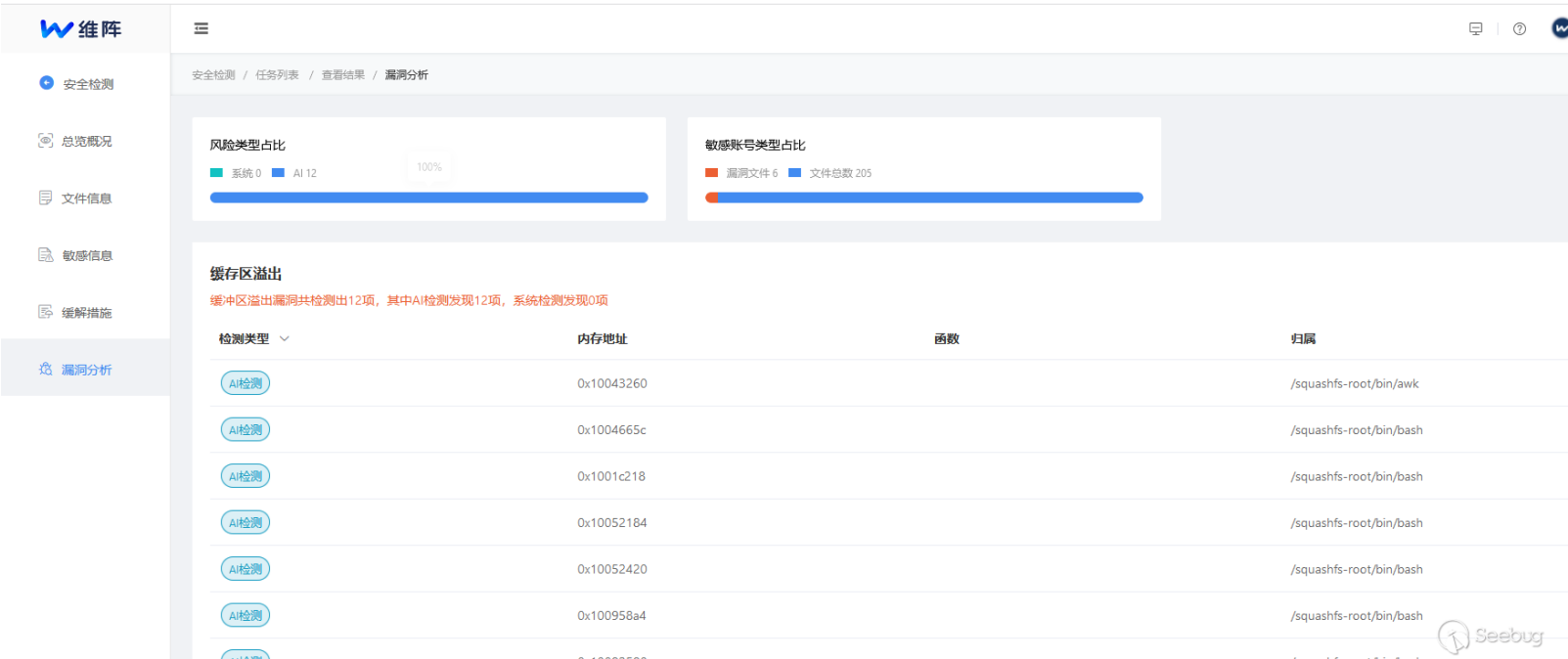


在附近查看，直接就可以发现感兴趣的passwd.basic 和shadow.basic。打开这两个文件可以发现一些账户和配置信息。根据前面的内容下载解密老版本的固件解压，对比文件是否有差异。



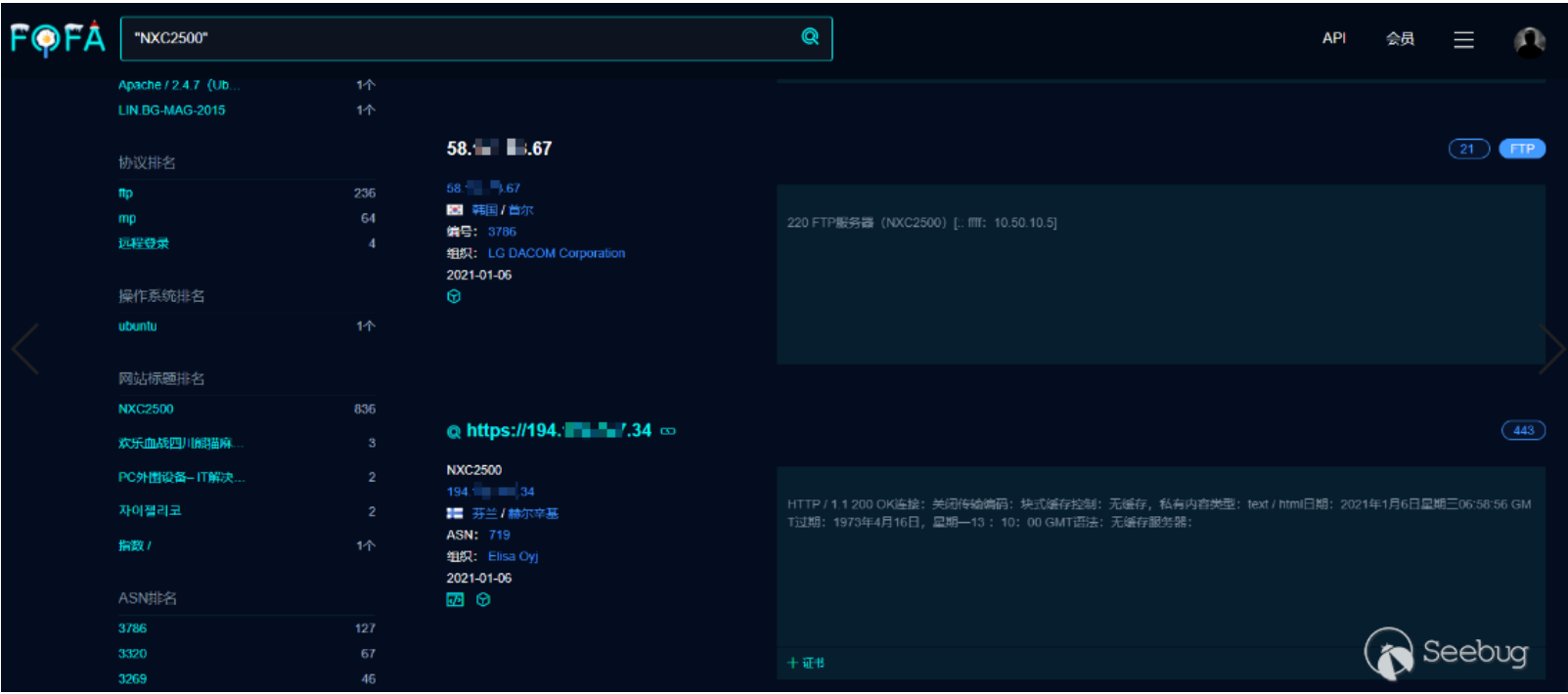
zyfwp是否真的被更换了吗？全局搜索这个字符串，会发现它在squashfs-root/usr/local/bin/capwap/capwap_srv二进制文件里面，这个时候已经可以打开ida进行分析，这种情况下一般都是会有所收获的。

打开维阵平台的漏洞分析模块，使用AI和系统共同自动化检测哪里可能存在漏洞，可以看到已经自动化分析出来不少有可能产生漏洞的文件和地址，有助于快速定位挖掘漏洞。

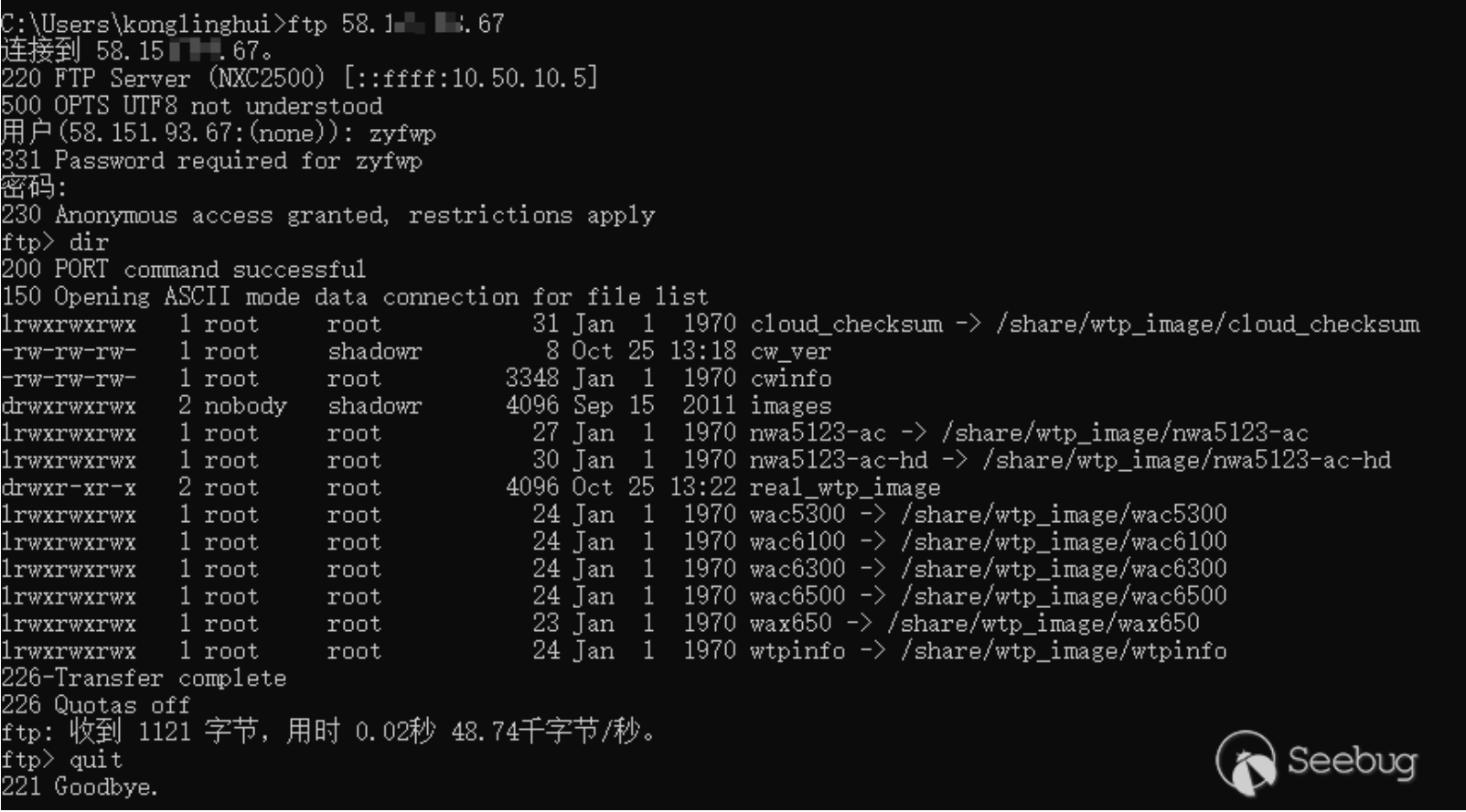


五、验证登录

搜索NXC2500，NXC系列是目前暂未修复的版本。



ftp登录



发现直接使用zyfwp账号密码就可以匿名登录

六、视频演示

相关视频请转至原文观看：<https://mp.weixin.qq.com/s/Ol3B3PFLLXLFF8ThA9nxEg>
(<https://mp.weixin.qq.com/s/Ol3B3PFLLXLFF8ThA9nxEg>)



本文由 Seebug Paper 发布，如需转载请注明来源。本文地址：<https://paper.seebug.org/1448/>
(<https://paper.seebug.org/1448/>)

(/users/author/?nickname=极光无限)

极光无限 (/users/author/?nickname=%E6%9E%81%E5%85%89%E6%97%A0%E9%99%90)

坐落于苏州金鸡湖畔的5A级写字楼苏州中心D座，是一家以安全技术为核心、AI技术为驱动的信息安全科技公司，由十多位来自国内外顶尖安全公司的资深安全专家和数位从事AI及信息安全领域研究的教授、博士进行技术领携。依托最前沿的图神经网络理论，致力于打造国际一流的AI自动化漏洞挖掘及APT自动攻防产品；将重点组建全球顶级的红蓝对抗及漏洞挖掘研究团队，以辅助和完善AI自动化安全产品研发。【招聘方向】：渗透测试、漏洞研究、安全开发。【人员需求】：苏州200人，成都50-60人。【办公地点】：优先：苏州，待选：成都。入职后，表现优秀有机会短期派往莫斯科，和众多国际顶级安全专家、国际CTF战队核心成员、IMO金牌以及顶尖从事数学、人工智能领域研究的教授、博士交流学习。

阅读更多有关该作者 (/users/author/?nickname=%E6%9E%81%E5%85%89%E6%97%A0%E9%99%90)的文章